Resumo executivo da apuração

Por Juan Matheus Rebello Santos — o hacker cego

Data: 30/10/2026
Escopo: subdomínios de órgãos públicos brasileiros que servem páginas de aposta (cloaking para robôs de busca) ou redirecionam o visitante para cassino.

Números

- **65.590 hosts** testados (Certificate Transparency + 5.571 municípios do IBGE + universidades federais)
- **304 hosts confirmados** com o kit de spam
- **25.563 hosts municipais** varridos em **27 estados**
- **25 hosts em 8 universidades** federais/estaduais
- **6 clusters de hospedagem compartilhada** respondem pela maior parte dos casos

---

Estados com infecção confirmada

Piauí 203 · Goiás 16 · São Paulo 12 · Mato Grosso do Sul 10 · Alagoas 8 · Pernambuco 8 · Paraná 6 · Minas Gerais 3 · Rio Grande do Sul 3 · Amazonas (INPA) 3 · Rio Grande do Norte 2 · Santa Catarina 2 · Espírito Santo 1 · Ceará 1 · Maranhão 1

Zero em 15 estados, incluindo Bahia (2.169 hosts), Paraíba (1.059), Ceará (780), Mato Grosso (838) e o Norte inteiro.

Instituições

Prefeituras e câmaras municipais em 13 estados; INPA; UFRGS (6); UFPI (7); USP (3); UFPB (3); UNIFESP (2); UnB (1); UFCSPA (1); IFC (1); Secretaria de Saúde de SC; Secretaria de Educação de Lages/SC.

Achados técnicos

1. **Cloaking por User-Agent**: mesma URL devolve 404/Cloudflare ao navegador e 130–250 KB
   de falso "Google Play" ao Googlebot.

2. **Três audiências**: robô (ficha falsa), celular vindo do Google (redirect JS em 1 s), WhatsApp (desafio Cloudflare).
3. **Redirecionamento é client-side**, não 302 no header — a maioria das varreduras não vê.
4. **Variante APK**: `/apk/` com slugs em tailandês, sem termo de aposta no caminho.
5. **Tomada aberta**: `hackathon.curitiba.pr.gov.br` serve gambling indonésio a todos.
6. **Forensics**: upload em `/wp-content/uploads/2026/09/...slot-thailand.jpg`, 990 KB, 30/09/2026 05:35 GMT — 22 dias após a Recomendação 17/2026 do CTIR.
7. **WordPress em 23 dos 25 hosts universitários**; nos municípios, stacks heterogêneas (Apache 2.2.22 de 2012, PHP 7.3/7.4 fora de suporte, nginx e LiteSpeed).

O que o governo já sabia

- **ALERTA 10/2023** (CTIR Gov): open redirect levando a apostas, cassinos e malware.
- **RECOMENDAÇÃO 17/2026** (08/09/2026): campanha ativa de cloaking em `.gov.br`, com injeção de rotas dinâmicas e persistência em Linux. Recomenda reinstalação, rotação de credenciais, noexec em /tmp, FIM.

Contato para notificação

CTIR Gov — ctir@ctir.gov.br · CERT.br — cert@cert.br